



Saint Columban College
College of Computing Studies
Pagadian City



Roboto Sans

Roboto Sans



Medium

Web Exploitation

picoCTF 2022

AUTHOR: MUBARAK MIKAIL

Description

The flag is somewhere on this web application not necessarily on the website. Find it.

Additional details will be available after launching your challenge instance.

This challenge launches an instance on demand.

Its current status is: **NOT_RUNNING**

Launch Instance

Hints ?

(None)

26,821 users solved



49% Liked



picoCTF{FLAG}

Submit Flag

Author: The Analyst: Hyposelenia

Challenge: Roboto Sans

Category: Web Exploitation

Date: 02/28/26



I. Objective

The objective of this challenge is to find a hidden flag by **examining parts of a website that are not immediately visible**, using hints from the challenge title and understanding how websites sometimes expose sensitive information through configuration files and encoded text.

II. Background

Websites are made up of many files behind the scenes, not just what users see on the screen. Some of these files are meant for search engines, developers, or administrators.

One such file is called robots.txt. While it is intended to guide search engine robots on what parts of a site they should avoid, it **does not actually block access**. Anyone who knows the file exists can view it.

This challenge teaches how attackers can:

- Read hidden configuration files
- Decode encoded messages (Base64)
- Discover sensitive paths that were never meant to be public

III. Tool Used

- **Web Browser** - Used to access and interact with the challenge website
- **Browser Developer Tools (Inspect)** - Used to view page structure and cookies
- **Base64 Decoder (Online Tool)** - Used to decode encoded strings found within the robots.txt file to reveal hidden directory paths.

IV. Methodology



Saint Columban College
College of Computing Studies
Pagadian City



1. Launched the challenge instance to generate the target website.

Its current status is: **NOT_RUNNING**

Launch Instance

2. Accessed the provided website link using a web browser.



3. Carefully read the challenge description, which stated that the flag was **not necessarily visible on the webpage itself**.

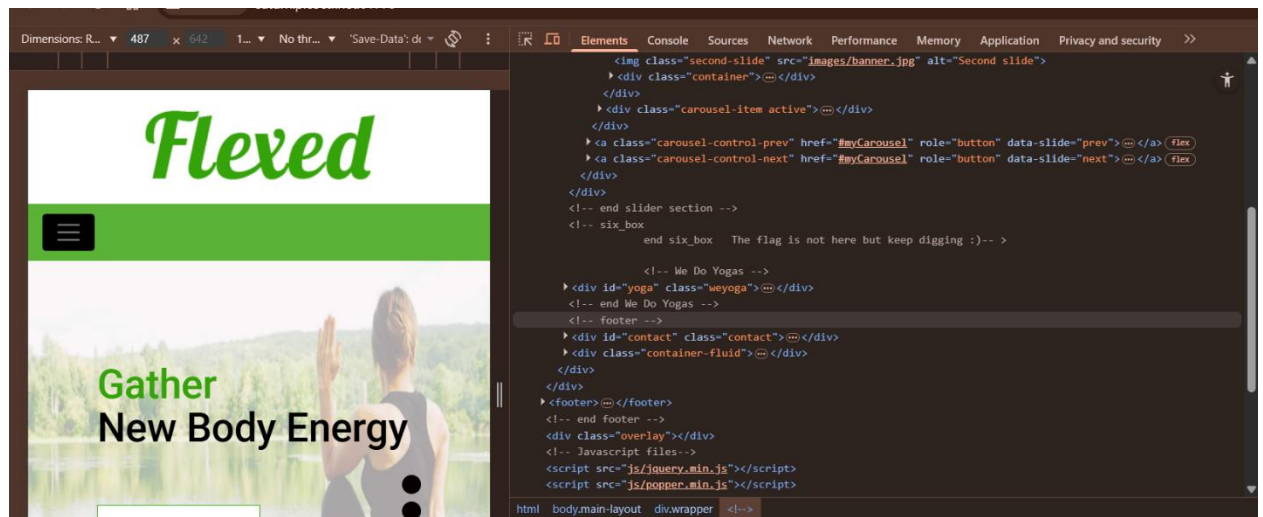
Description

The flag is somewhere on this web application not necessarily on the website. Find it.

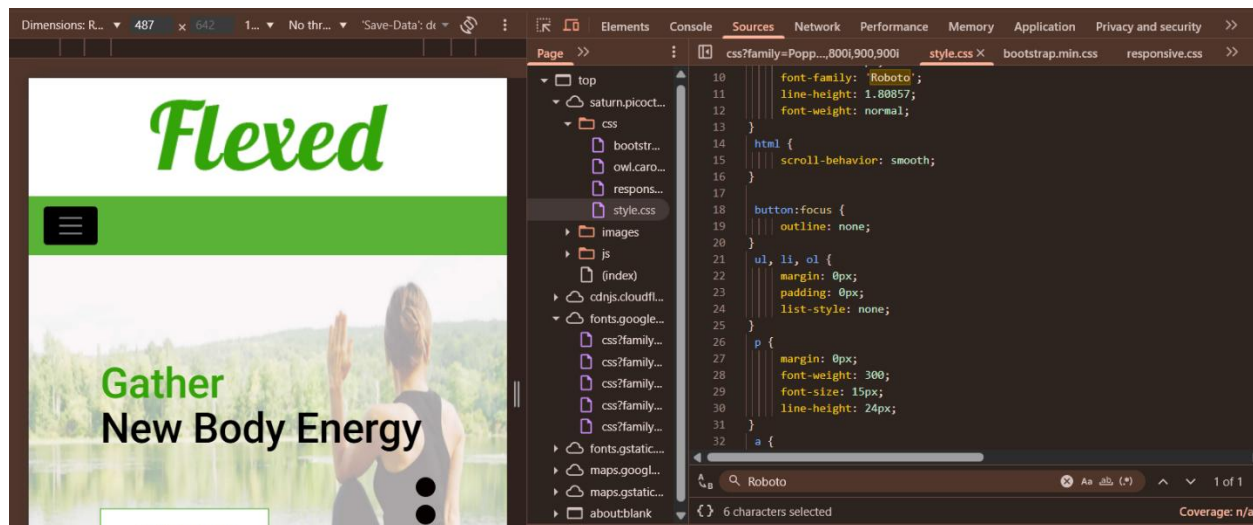
4. Opened the Browser Developer Tools (Inspect) to examine the website's structure, starting with index.html.



Saint Columban College
College of Computing Studies
Pagadian City



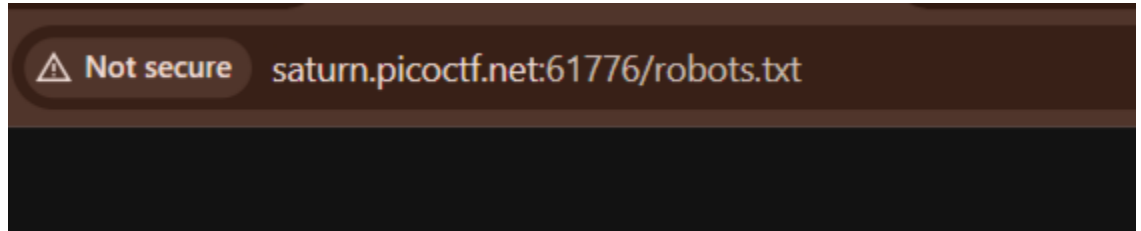
5. Used the browser's search function (Ctrl + F) to look for any obvious flag patterns within the HTML and CSS files.



6. After finding no results, analyzed the challenge title “**Roboto Sans**”, which suggested a hint related to **robots**.



7. Manually added /robots.txt to the end of the website URL to check for restricted or hidden paths.



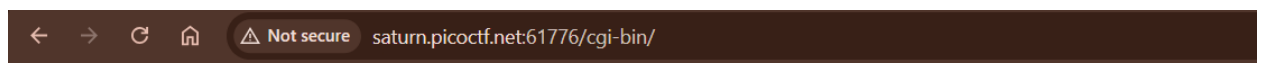
8. Observed that the robots.txt file contained:

Two disallowed directories

Three encoded strings

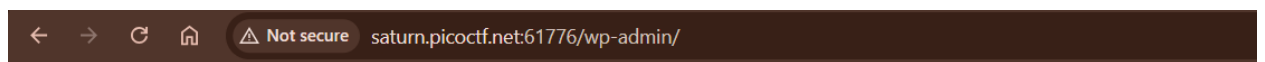
```
User-agent *  
Disallow: /cgi-bin/  
Think you have seen your flag or want to keep looking.  
  
ZmxhZzEudHh0;anMvbXlmaW  
anMvbXlmaWxlLnR4dA==  
svssshjweuiwl;oiho.bsvdaslejg  
Disallow: /wp-admin/
```

9. Attempted to directly access the two disallowed directories (/cgi-bin/ and /wp-admin/), but found no useful content.



404 Not Found

nginx/1.21.6



404 Not Found

nginx/1.21.6



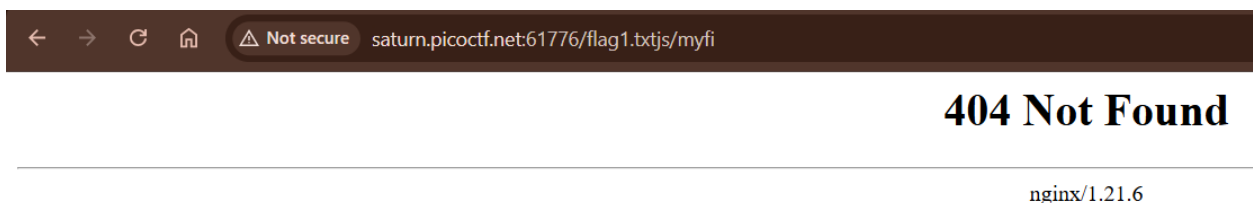
10. Copied the three encoded strings from robots.txt and decoded them using a Base64 decoder.

```
ZmxhZzEudHh0;anMvbXlmaW  
anMvbXlmaWx1LnR4dA==  
svssshjweuiwl;oiho.bsvdaslejj  
Disallow: /wp-admin/
```

11. Identified that two decoded results were directory paths.

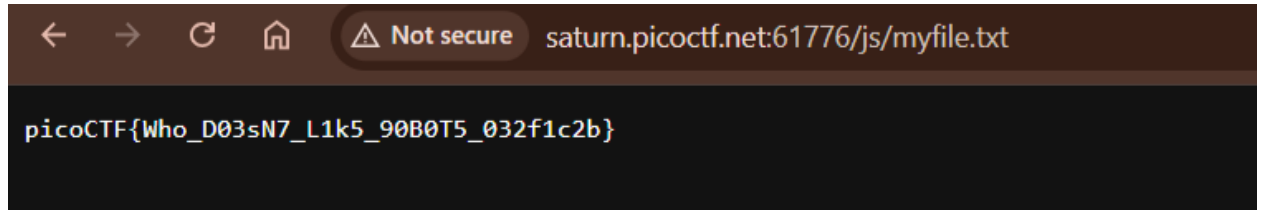
Input	Input	Input
ZmxhZzEudHh0;anMvbXlmaW	anMvbXlmaWx1LnR4dA==	svssshjweuiwl;oiho.bsvdaslejj
Output flag1.txtjs/myfi	Output js/myfile.txt	Output 2û,2CANðzè°•j »/u«%z8

12. Accessed the decoded directory paths through the browser.



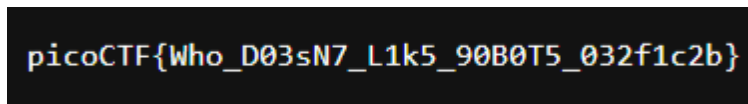


13. Successfully located the flag within the file /js/myfile.txt.



V. Result

picoCTF{Who_D03sN7_L1k5_90B0T5_032f1c2b}



VI. Explanation

Why the title “Roboto Sans” mattered

The title is a **hint**:

- **Roboto** → Robot
- **Sans** → Without / stripped

This suggests thinking about **robots**, which leads directly to robots.txt, a common file on websites.

What is robots.txt? (Very simple explanation)

Imagine a sign on a door that says:

“Please don’t come in.”

That sign is for **polite robots**, not locks. Humans can still open the door.

That’s exactly what robots.txt is:



- It tells search engine bots what **not** to crawl
- It does **not** protect files or folders

Why checking /robots.txt worked

When /robots.txt was opened, it revealed:

- Two **disallowed directories**
- Three **encoded strings**

This is a mistake because:

- Attackers can read it
- Attackers can decode encoded values
- Hidden paths become discoverable

What is Base64 and why decoding worked

Base64 is **encoding**, not encryption.

Think of it like:

- Writing a message using symbols instead of letters
- Anyone who knows the rules can convert it back

Because Base64 is reversible, decoding the strings revealed **actual directory paths**, one of which led directly to the flag.

What went wrong in this challenge

1. Sensitive paths were exposed in robots.txt
2. Encoded directories were publicly visible
3. No access control protected the discovered files
4. The website relied on “hiding” instead of securing



This allowed the flag to be accessed simply by:

- Reading
- Decoding
- Visiting a URL

How this should be prevented

- Never place sensitive paths in robots.txt
- Use proper server-side access control
- Do not rely on Base64 to hide secrets
- Restrict file access at the server level

VII. Conclusion

This challenge demonstrates how **small configuration mistakes** can lead to serious information leaks. By understanding hints, exploring robots.txt, and decoding Base64 strings, the hidden flag was successfully retrieved. The key lesson is that **security through obscurity does not work**, and developers must properly protect sensitive resources instead of simply hiding them.

— The Analyst: Hyposelenia